

CHECKLIST JURIDIQUE & RGPD – PLATEFORME IMMOBILIÈRE MVP

Document : Checklist Juridique & RGPD – MVP

Objet : Garantir la conformité légale et la sécurité des données pour le MVP de la plateforme immobilière.

Public : Équipe produit, développeurs, data engineers, équipe juridique

1. Consentement Utilisateur

- Collecte **explicite** pour chaque type de données (email, IP, informations sur le bien, logs).
 - Opt-in **clair et séparé** pour :
 - données personnelles des utilisateurs
 - flux agences partenaires
 - annonces déposées par particuliers
 - Historisation des consentements et **versioning** pour audit légal.
-

2. Données Personnelles Traitées

- Email, login, IP, préférences, alertes.
 - Données sur les biens déposées **volontairement** par utilisateurs et agences.
 - Flux partenaires contractuels validés par contrat **DPA**.
-

3. Bases Légales

- **Art. 6 GDPR** : Consentement explicite ou traitement nécessaire à la fourniture du service.
 - **Art. 9 GDPR** : Pour les données sensibles (ex. DPE) uniquement traitement légal et non discriminatoire.
 - Archivage légal pour les transactions immobilières selon obligations CNIL et loi française.
-

4. Droits des Utilisateurs

- Droit d'**accès**, de **rectification**, de **suppression**, et de **portabilité**.
 - Droit d'opposition au **profilage automatisé**.
 - Procédures internes pour respecter les délais CNIL.
-

5. Documentation Obligatoire

- CGU B2C et B2B distinctes et validées par juriste.
 - Privacy Policy détaillée et facilement accessible.
 - Registre RGPD interne documentant :
 - finalité des traitements
 - durées de conservation
 - responsables de traitement
 - Contrats **Data Processing Agreement (DPA)** signés avec tous les partenaires manipulant des données.
-

6. Données Dérivées et Open Data

- Les données dérivées (scores, indices, tendances) sont calculées **uniquement à partir de données publiques et open data** (DVF, DPE ADEME, INSEE, Cadastre, IGN).
 - Aucune revente de données personnelles.
 - Traçabilité complète des calculs et sources pour audit juridique et conformité.
-

7. Sécurité et Conformité

- Hébergement des données uniquement **dans l'UE**.
 - Journaux d'accès et **audit trail** pour toutes les actions sensibles.
 - Sécurisation des API et flux de données (HTTPS, authentification forte).
 - Politique de retention data conforme au RGPD et lois françaises.
-

8. Risques Juridiques Résiduels

- Utilisation de données partenaires sans opt-in.
 - Collecte indirecte via cookies ou trackers non justifiés.
 - Absence de consentement clair pour alertes et notifications marketing.
-

9. Points de Vérification Avant Déploiement

- Tous les formulaires disposent d'**opt-in vérifiable**.
- Audit interne RGPD réalisé et validé par juriste.
- Contrats DPA signés avec tous les partenaires.
- Politique de données dérivées et scores vérifiée et documentée.

- Processus pour droits utilisateurs testé (accès, rectification, suppression, portabilité).
-

10. Annexes et Références

- **Textes légaux à intégrer et suivre :**
 - RGPD (Regulation EU 2016/679)
 - Loi Informatique et Libertés (France, version consolidée)
 - Décrets CNIL sur données sensibles et consentement
- **Documentation interne :**
 - Modèle CGU B2C et B2B
 - Modèle Privacy Policy
 - Procédures internes pour audit et reporting